

Contents

Linux privilege layers	3
----------------------------------	---

Security Azimuth Check

```
<div style="position:absolute; inset:-80px auto auto -80px; width:220px; height:220px; border:1px solid #cbd5e1; border-radius:10px; margin-top:10px; margin-bottom:10px; margin-left:10px; margin-right:10px; background-color:#f8f9fa; padding:10px; text-align:center; color:#343a40; font-weight:bold; font-size:1.2em;">Security Azimuth Check</div>
<div style="position:absolute; inset:auto -70px -70px auto; width:240px; height:240px; border:1px solid #cbd5e1; border-radius:10px; margin-top:10px; margin-bottom:10px; margin-left:10px; margin-right:10px; background-color:#f8f9fa; padding:10px; text-align:center; color:#343a40; font-weight:bold; font-size:1.2em;">Security Azimuth Check</div>
<h1 class="audit-title" style="margin:.85rem 0 .55rem; font-size:2.1rem; line-height:1.08; color:#343a40; font-weight:bold;">Security Azimuth Check</h1>
<p class="audit-text" style="max-width:60rem; margin:0 0 1rem; color:#cbd5e1; font-size:1.2em; font-weight:bold;">Security Azimuth Check</p>
<div style="display:flex; justify-content:center; margin-top:1rem;">
```

Disposition: Revise and strengthen

Strongest area: Network segmentation

Weakest area: Validation evidence

Framework lens: NIST CSF 2.0

Control lens: CIS Controls v8

Protocol refs: RFC 1918 / RFC 4193

Rating methodology reference

Rating area	Scale used	Meaning	Source
National Institute of Standards and Technology (NIST) Cybersecurity Framework (CSF) 2.0 implementation tier	Tier 1–4	Tier 1 = Partial, Tier 2 = Risk-Informed, Tier 3 = Repeatable, Tier 4 = Adaptive	NIST Cybersecurity Framework (CSF) 2.0

Rating area	Scale used	Meaning	Source
Center for Internet Security (CIS) Controls v8 maturity	Level 1–5 (internal mapping)	Internal scoring shorthand used to describe how completely the documented controls appear to be implemented and evidenced; this is an audit-layer maturity summary, not an official CIS numeric scale	CIS Controls v8 Overview
CIS Controls v8 implementation groups	IG1–IG3	IG1 = basic cyber hygiene, IG2 = additional protections for more complexity, IG3 = mature protections for higher-risk environments	CIS Controls Implementation Groups
NIST CSF function status language	Weak / Partial / Moderate / Strong	Plain-language reviewer shorthand used to summarize how well the current plan addresses a CSF function based on the evidence present in the document	NIST Cybersecurity Framework (CSF) 2.0 Core

Rating area	Scale used	Meaning	Source
Objective evidence strength	Low / Emerging / Established	Reviewer shorthand for how much validation evidence is actually included, such as diagrams, rule matrices, logs, captures, test records, and recovery proof	NIST Cybersecurity Framework (CSF) 2.0

Scoring note: This review uses NIST CSF 2.0 implementation tiers as the primary maturity language and CIS Controls v8 as the control-family and implementation-group lens.

```

<div class="audit-panel">
  <h3>What the current plan does well</h3>
  <p>The plan is strongest in segmentation, internal boundary control, and reduction of easy
</div>
<div class="audit-panel">
  <h3>What the current plan does not yet prove</h3>
  <p>The writeup does not yet provide objective validation artifacts such as rule exports, p
</div>
<div class="audit-panel">
  <h3>Overall assessment</h3>
  <p>The design intent is better than the documentation quality. The network policy model ap
</div>

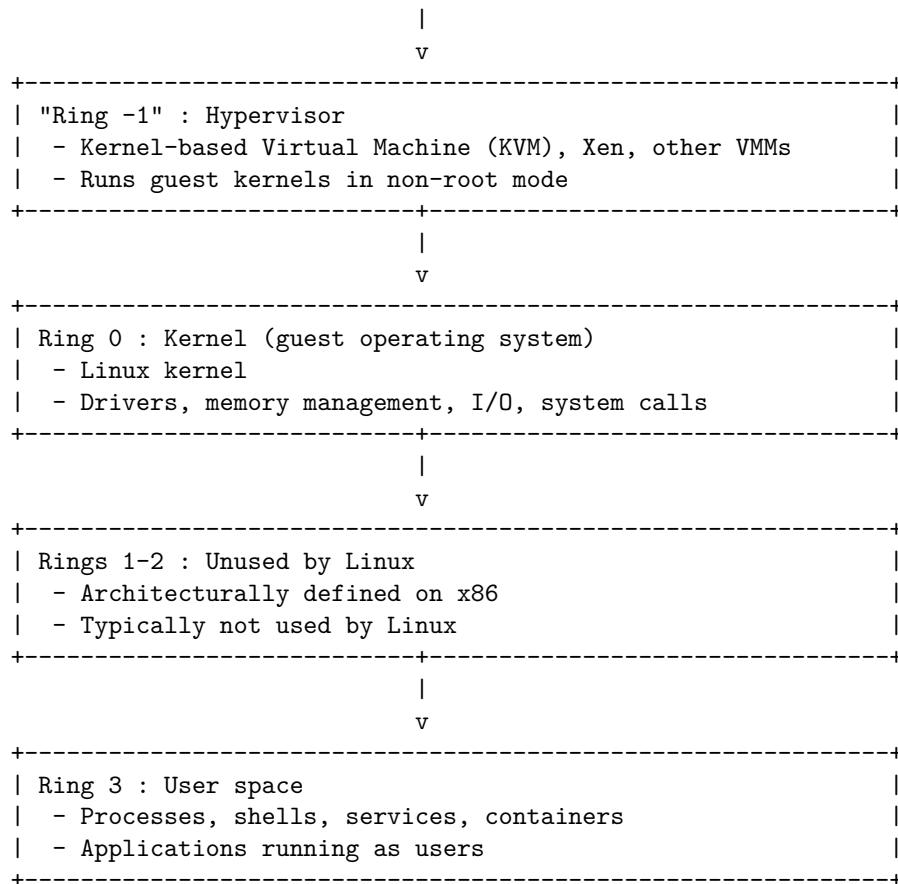
```

Linux privilege layers

```

+-----+
| "Ring -3" : Firmware / Management Engine |
| - Unified Extensible Firmware Interface (UEFI) / BIOS |
| - Intel Management Engine (ME) / AMD Platform Security |
| Processor (PSP), Baseboard Management Controller (BMC) |
+-----+
|
v
+-----+
| "Ring -2" : System Management Mode (SMM) / Secure Monitor |
| - System Management Mode (SMM) |
| - Low-level monitors / EL3-equivalent |
+-----+

```



Framework-based scorecard

Framework-based scorecard

```

<div class="audit-score">
  <div class="audit-score-head"><span>Identify (NIST CSF) and Network (CIS)</span><span class="audit-pill">Tier 1</span></div>
  3 / CIS Level ~2-3</span></div>
  <div class="audit-meter"><span style="width:80%"></span></div>
  <p>VLAN segmentation, administrative-device exceptions, and demilitarized zone (DMZ) separation</p>
</div>
<div class="audit-score">
  <div class="audit-score-head"><span>Access control (NIST / CIS)</span><span class="audit-pill">Tier 1</span></div>
  <div class="audit-meter"><span style="width:60%"></span></div>
  <p>The plan shows partial least-privilege thinking through aliases and narrow exceptions, but lacks explicit controls for least-privilege</p>
</div>
<div class="audit-score">
  <div class="audit-score-head"><span>Detect (NIST CSF)</span><span class="audit-pill">Tier 1</span></div>
  <div class="audit-meter"><span style="width:60%"></span></div>

```

<p>Suricata and Zenarmor add meaningful detection capability, but the report does not yet

</div>

Plan element	Observed strength	Objective weakness	Recommendation
Dual 10G physical separation for trusted vs. DMZ traffic	Strong boundary separation concept that reduces accidental mixing of trust zones.	The report does not show interface diagrams, switchport assignments, or verification that traffic cannot bypass intended separation.	Add deployment-specific notes here.
VLAN segmentation into management, trusted, private servers, DMZ, and Internet of Things (IoT) / guest	Good segmentation pattern consistent with reducing lateral movement and scoping exposure.	No rule matrix, inter-VLAN flow table, or validation test results are shown. There is also no asset inventory tied to each VLAN.	Add VLAN-specific findings here.
RFC 1918-based internal block rules	Good default-deny intent for IPv4 internal traffic between zones.	RFC 1918 applies to IPv4 private space only, so the report must clearly separate IPv4 logic from IPv6 logic and show rule parity.	Add IPv4 rule review notes here.

5

Plan element	Observed strength	Objective weakness	Recommendation
Administrative device alias for management access	Better than broad subnet trust because it narrows privileged access to named systems.	Internet Protocol (IP)-based trust is not the same as identity assurance; no MFA, device health, certificate trust, or administrative session controls are documented.	Add management-plane concerns here.
Native local area network (LAN) lock to network-hardware alias	Strong anti-misuse idea for untagged infrastructure ports.	The report does not prove port-security behavior, switch configuration, or what happens during switch replacement, emergency maintenance, or mispatching.	Add switch and port validation notes here.
DMZ to private-server micro-allowlisting	Strongest control in the writeup because it scopes cross-zone exposure to named application paths.	No service dependency map, allowed-port inventory, or validation test is included, and no host-layer hardening is documented for the allowlisted targets.	Add service-path review notes here.
Forced DNS via Network Address Translation (NAT) redirect on port 53	Useful for traditional DNS control and policy enforcement.	The report does not discuss DNS over HTTPS, DNS over TLS, QUIC-based bypass paths, or how exceptions are detected and blocked.	Add DNS bypass observations here.

Plan element	Observed strength	Objective weakness	Recommendation
IPv6 Unique Local Address (ULA) with NAT66	Shows awareness that IPv6 must be governed explicitly and separately.	The report should justify NAT66 operationally, define policy parity with IPv4, and explain residual risks and tradeoffs.	Add IPv6 architecture notes here.
Zenarmor Next-Generation Firewall (NGFW) on internal interfaces	Adds application visibility and policy depth beyond port-level filtering.	No evidence is shown for policy sets, exception handling, update cadence, or how detection output feeds response.	Add deep packet inspection (DPI) policy notes here.
Suricata Intrusion Prevention System (IPS) on WAN / DMZ edge	Appropriate perimeter detection and block control for exposed services.	No description of ruleset source, tuning, alert fatigue handling, or packet-drop validation is provided.	Add IPS tuning notes here.
Geographic IP (GeoIP) restrictions on WAN forwards	Can reduce opportunistic scan exposure.	GeoIP is only a coarse filter; it is not identity, and it is bypassable through Virtual Private Networks (VPNs), proxies, and cloud egress regions. The report overstates its effect with “99%” language without measurement evidence.	Add exposure-reduction notes here.

Strengths

Observed strengths

```

<div class="audit-card">
  <strong>1. Segmentation is intentional rather than cosmetic.</strong>
  <p>The current plan separates management, user, server, public, and untrusted device roles
  <details><summary>Recommendation</summary><textarea>This segmentation model is a strong fo
</div>
<div class="audit-card">
  <strong>2. The plan uses default-deny thinking for east-west traffic.</strong>
  <p>The described RFC 1918 block model and application-specific exceptions reflect a genuin
  <details><summary>Recommendation</summary><textarea>The default-deny approach for east-wes
</div>
<div class="audit-card">
  <strong>3. The plan recognizes IPv6 as a separate policy domain.</strong>
  <p>Many otherwise competent network writeups ignore IPv6 entirely; this one does not. The
  <details><summary>Recommendation</summary><textarea>Treating IPv6 as a first-class policy
</div>
<div class="audit-card">
  <strong>4. Public-service exposure is narrowed through multiple layers.</strong>
  <p>The DMZ design, micro-allowlisting, IPS, and GeoIP filtering show that exposure control
  <details><summary>Recommendation</summary><textarea>For the next revision, document each e
</div>

```

Weaknesses

Recommended corrections

Each card below includes an inline reviewer comment area intended as a working space for future reviewers to capture environment-specific notes and decisions.

```

<div class="audit-card">
  <strong>1. The report overstates assurance relative to evidence.</strong>
  <p>The document frequently claims outcomes such as trapping attackers, eliminating exposure
  <details><summary>Recommendation</summary><textarea>Please replace broad outcome claims su
</div>
<div class="audit-card">
  <strong>2. Identity and privileged access controls are under-documented.</strong>
  <p>The current plan treats administrative devices as privileged based on IP assignment, bu
  <details><summary>Recommendation</summary><textarea>The current writeup focuses on which l
</div>
<div class="audit-card">
  <strong>3. Host and workload hardening are mostly absent from the writeup.</strong>
  <p>The report is strong on network policy but thin on endpoint, container, virtual machine
  <details><summary>Recommendation</summary><textarea>Network policy is well developed, but
</div>
<div class="audit-card">
  <strong>4. Detection controls are described, but response workflow is not.</strong>
  <p>The writeup names Suricata and Zenarmor, but it does not explain where alerts go, who r
  <details><summary>Recommendation</summary><textarea>The plan needs to show how detections
</div>

```



```

<div class="audit-card">
  <strong>5. Several claims need narrower and more accurate wording.</strong>
  <p>Phrases like "physically trapped," "violently drops," "God Mode," and "99%" read as cha
  <details><summary>Recommendation</summary><textarea> Please revise promotional or visceral
</div>

```

Recommended objective metrics

Recommended objective metrics

Control area	Metric to add	Why it matters
VLAN segmentation	Number of authorized inter-VLAN flows vs. denied flows per review period	Demonstrates that segmentation is defined and measured rather than assumed.
Administrative access	Count of management interfaces exposed; count of systems allowed to reach them	Shows whether privileged access scope is minimized.
DNS enforcement	Percentage of DNS requests observed through approved resolver path; count of blocked direct DNS attempts	Validates whether “forced DNS” is actually working.
Suricata	Alerts per day, true-positive rate after tuning, drop count for relevant signatures	Converts IPS claims into measurable operational effectiveness.
Zenarmor	Blocked application categories, exceptions granted, update cadence	Shows whether Layer 7 (L7) policy is governed and maintained.
Public exposure	Number of WAN-exposed services, allowed source countries, authentication controls per service	Makes internet exposure concrete and reviewable.
Recovery	Backup frequency, restore test frequency, last successful restore date	Addresses resilience, not just prevention.
Change control	Firewall rule review interval, number of stale rules removed, documented exceptions	Prevents segmentation drift over time.

These metrics correspond directly to the framework-based scorecard above, and collecting them regularly will allow future reviews to assign NIST CSF tiers and CIS Controls v8 maturity levels based on observed data rather than design intent alone.

Standards and reference corrections

Standards and reference corrections

```
<div class="audit-card">
  <strong>RFC 1918 usage</strong>
  <p>Use RFC 1918 only when referring to the IPv4 private ranges 10.0.0.0/8, 172.16.0.0/12,
  <details><summary>Recommendation</summary><textarea>In this environment, please be explicit
</div>
<div class="audit-card">
  <strong>IPv6 ULA usage</strong>
  <p>Use RFC 4193 when discussing Unique Local Addresses (ULAs) for IPv6. If NAT66 remains p
  <details><summary>Recommendation</summary><textarea>For the next revision, please include
</div>
<div class="audit-card">
  <strong>Compliance wording</strong>
  <p>Do not imply Federal Information Processing Standards (FIPS), NIST, or similar complian
  <details><summary>Recommendation</summary><textarea>When you reference frameworks or stand
</div>
```

Framework alignment summary

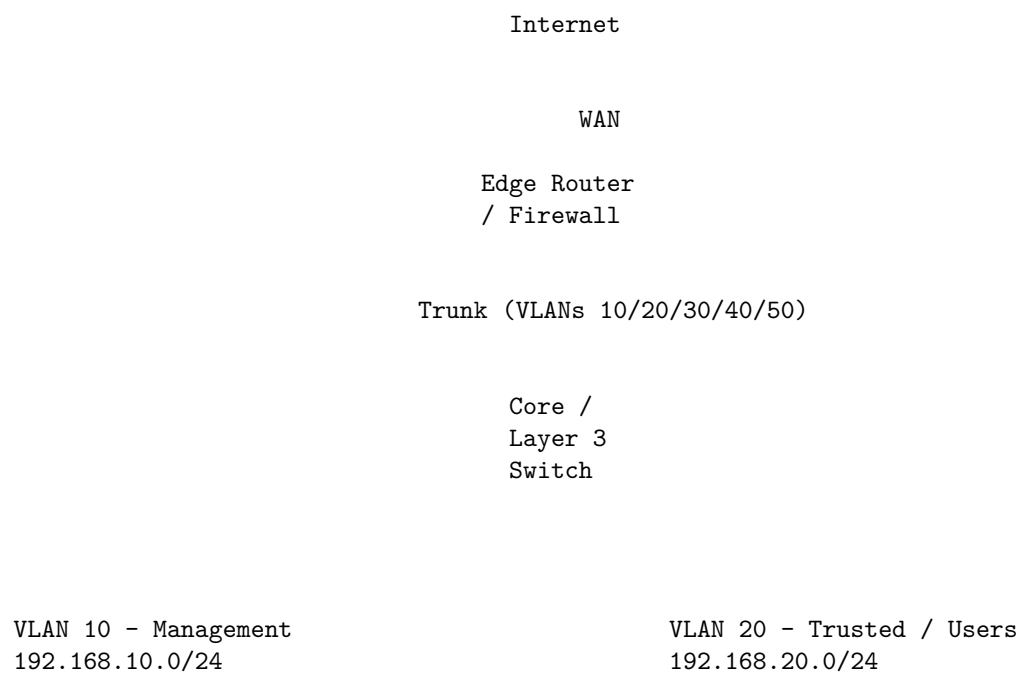
Framework area	Current status	Notes
NIST CSF — Identify	Partial	Zones and asset roles are implied, but a formal asset inventory and dependency mapping are not shown.
NIST CSF — Protect	Moderate	Segmentation and filtering are the strongest documented areas.
NIST CSF — Detect	Partial	IPS and NGFW are present, but alert operations are undocumented.
NIST CSF — Respond	Weak	No incident workflow, ownership, or escalation path is described.
NIST CSF — Recover	Weak	No backup, restore, or resilience testing evidence is described.

Framework area	Current status	Notes
CIS Controls v8 — Network infrastructure management	Moderate	Good control intent, weak evidence and maintenance documentation.
CIS Controls v8 — Access control management	Partial	Alias-based narrowing exists, but identity assurance and administrative governance are thin.
CIS Controls v8 — Audit log management	Weak	Logging and review workflow are not documented.
CIS Controls v8 — Secure configuration	Partial	Configuration intent is strong, but baselines and change control are not shown.

Reviewer guidance:

The current plan should be graded as a promising technical design that needs a more rigorous

Example homelab network diagram



- Hypervisor management (Proxmox / ESXi)
- Switch / wireless access point management
- Internet Protocol addresses
- Out-of-band Intelligent Platform Management Interface (IPMI) / BMC
- Jump host / bastion
- Workstations / laptops
- Administrative workstation
- Developer boxes
- Internal print / file

upstream only from admin alias

egress to core services

tightly controlled ACLs / firewall rules

VLAN 30 - Server / Private Services
192.168.30.0/24

VLAN 40 - DMZ / Public Services
192.168.40.0/24

- Internal DNS / DHCP
- Internal Git / continuous integration
- Monitoring (Prometheus, Grafana)
- Internal databases
- Public-facing web apps
- Reverse proxy
- VPN termination
- Any test internet-facing labs

micro-allowlist from DMZ
(only specific ports / hosts)

east-west default-deny between VLANs

VLAN 50 - IoT / Guest
192.168.50.0/24

- Smart televisions, cameras
- Guest Wi-Fi clients
- Other untrusted devices
- Only allowed out to:
 - Internet (via firewall rules)
 - Very specific internal services (if needed)
- No direct reachability to Management or Server VLANs

Example documented configuration profiles

These example configuration profiles are not drop-in templates, but documented baselines showing how this homelab could be aligned with the segmentation and detection intent described earlier. They should be adapted to the actual interfaces, VLAN names, rulesets, and policy objects used in production.

Zenarmor documented policy profile

```
# Zenarmor policy baseline (documented configuration profile)  
# Apply in OPNsense Zenarmor user interface (UI)
```

```
deployment:  
  mode: routed  
  protected_interfaces:  
    - em1    # LAN_TRUSTED  
    - em2    # LAN_IOT  
    - em3    # DMZ  
  security_zones:  
    em1: lan  
    em2: iot  
    em3: dmz  
  cpu_pinning: enabled  
  reporting_database: local  
  
policies:  
  - name: MGMT_SERVERS_STRICT  
    enabled: true  
    scope:  
      source_zones: [lan]  
      destination_zones: [lan, dmz]  
      vlan_targets: [management, private_servers]  
    action: allow_with_restrictions  
    app_controls:  
      block_categories:  
        - Anonymizers  
        - PeerToPeer  
        - Malware  
        - Phishing  
        - CryptoMining  
        - DynamicDNS  
        - RemoteAccessTools  
      monitor_categories:  
        - AITools  
        - StorageBackup  
    web_controls:  
      block_risky_domains: true  
      safe_search: true  
      block_new_registered_domains: true  
    tls_inspection: disabled  
    logging:  
      log_allowed_sessions: false  
      log_blocked_sessions: true  
      retention_days: 30  
    exceptions:
```

```

- name: allow_github_for_admin_updates
  target: github.com
  justification: package and code updates
  review_interval_days: 90

- name: IOT_GUEST_RESTRICTED
  enabled: true
  scope:
    source_zones: [iot]
    destination_zones: [wan]
    vlan_targets: [iot_guest]
  action: default_deny
  app_controls:
    allow_categories:
      - DNS
      - NTP
      - VendorCloudServices
    block_categories:
      - Anonymizers
      - PeerToPeer
      - SocialMedia
      - RemoteAccessTools
      - StreamingMedia
      - Malware
      - CryptoMining
  web_controls:
    block_risky_domains: true
    block_new_registered_domains: true
  logging:
    log_allowed_sessions: true
    log_blocked_sessions: true
    retention_days: 30
  exceptions:
    - name: allow_camera_vendor_cloud
      target: camera-vendor.example
      justification: required for device operation
      review_interval_days: 90

- name: DMZ_MONITORED
  enabled: true
  scope:
    source_zones: [dmz]
    destination_zones: [wan, lan]
    vlan_targets: [dmz]
  action: allow_with_restrictions
  app_controls:

```

```

    block_categories:
      - PeerToPeer
      - Anonymizers
      - Malware
      - RemoteAccessTools
    monitor_categories:
      - Web
      - DNS
      - TLS
  logging:
    log_allowed_sessions: true
    log_blocked_sessions: true
    retention_days: 60
  exceptions: []

maintenance:
  policy_review_interval_days: 90
  signature_update_policy: automatic
  stale_exception_removal: enabled

Suricata example configuration

# /etc/suricata/suricata.yaml
%YAML 1.1
---

vars:
  address-groups:
    HOME_NET: "[192.168.10.0/24,192.168.20.0/24,192.168.30.0/24,192.168.40.0/24,fd00:10::/64]"
    EXTERNAL_NET: "!$HOME_NET"

  default-log-dir: /var/log/suricata/

  af-packet:
    - interface: igb0
      cluster-id: 99
      cluster-type: cluster_flow
      defrag: yes
      use-mmap: yes
      tpacket-v3: yes
      ring-size: 200000
      block-size: 1048576
      buffer-size: 65535
    - interface: igb1
      cluster-id: 98
      cluster-type: cluster_flow
      defrag: yes

```

```

    use-mmap: yes
    tpacket-v3: yes
    ring-size: 200000
    block-size: 1048576
    buffer-size: 65535

outputs:
  - eve-log:
      enabled: yes
      filetype: regular
      filename: eve.json
      community-id: true
      xff:
        enabled: no
      types:
        - alert:
            payload: no
            packet: no
            http-body: no
            tagged-packets: yes
            metadata: yes
        - anomaly:
            enabled: yes
        - dns:
            query: yes
            answer: yes
        - http:
            extended: yes
        - tls:
            extended: yes
        - ssh
        - flow
        - netflow
        - stats:
            totals: yes
            threads: yes
        - drop:
            alerts: yes
            flows: all

rule-files:
  - suricata.rules
  - local.rules

detect-engine:
  - profile: medium

```



```

        custom-values:
            toclient-groups: 3
            toserver-groups: 25
        - rule-reload: true

stream:
    memcap: 512mb
    checksum-validation: yes
    inline: auto

app-layer:
    protocols:
        tls:
            enabled: yes
        http:
            enabled: yes
        dns:
            enabled: yes
        ssh:
            enabled: yes

threshold-file: /etc/suricata/threshold.config
classification-file: /etc/suricata/classification.config
reference-config-file: /etc/suricata/reference.config
# /etc/suricata/rules/local.rules

drop tcp !$HOME_NET any -> 192.168.10.1 443 (msg:"DROP unauthorized access to firewall GUI";

alert udp 192.168.50.0/24 any -> !192.168.30.53 53 (msg:"ALERT IoT direct DNS bypass attempt";

alert tcp !192.168.10.0/24 any -> 192.168.10.0/24 22 (msg:"ALERT non-management SSH attempt";

# /etc/suricata/threshold.config

suppress gen_id 1, sig_id 2010935, track by_src, ip 192.168.20.15
threshold gen_id 1, sig_id 2001219, type both, track by_src, count 5, seconds 60

```